

Unprotected admin functionality with unpredictable URL

Topic: Authorization (Access Control) | Difficulty: Apprentice

Description

The application uses an unpredictable URL for the admin panel as an obscurity measure. However the URL is hardcoded in client-side JavaScript served to all users. By inspecting page source any user can discover and access the admin panel without authentication, demonstrating that security by obscurity is not a valid control.

Steps to Exploit

1. Navigate to the application home page.
2. View the page source (Ctrl+U) or open Developer Tools > Sources.
3. Search for 'admin' in the JavaScript source.
4. Locate the hardcoded admin panel URL in the script.
5. Navigate directly to that URL in the browser.
6. Access the admin panel and delete user 'carlos'.

Proof of Concept

JavaScript Source Snippet:

```
var isAdmin = false;
if (isAdmin) {
  adminPanelTag.setAttribute('href', '/admin-panel-kxgzb5');
}
```

Direct Access:

```
GET /admin-panel-kxgzb5 HTTP/1.1 -> 200 OK (no authentication enforced)
```

Impact

- Admin panel URL discovered from client-side JavaScript by any user.
- Unauthenticated access to all administrative functionality.
- Security by obscurity is completely ineffective as an access control.

Mitigation / Remediation

1. Never rely on URL obscurity as an access control mechanism.
2. Enforce server-side authentication on all admin routes regardless of URL complexity.
3. Avoid embedding sensitive paths or conditional logic in client-side JavaScript.
4. Implement RBAC and audit every route for proper server-side authorization.

CVSS Score

CVSS v3.1: 8.1 (High)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

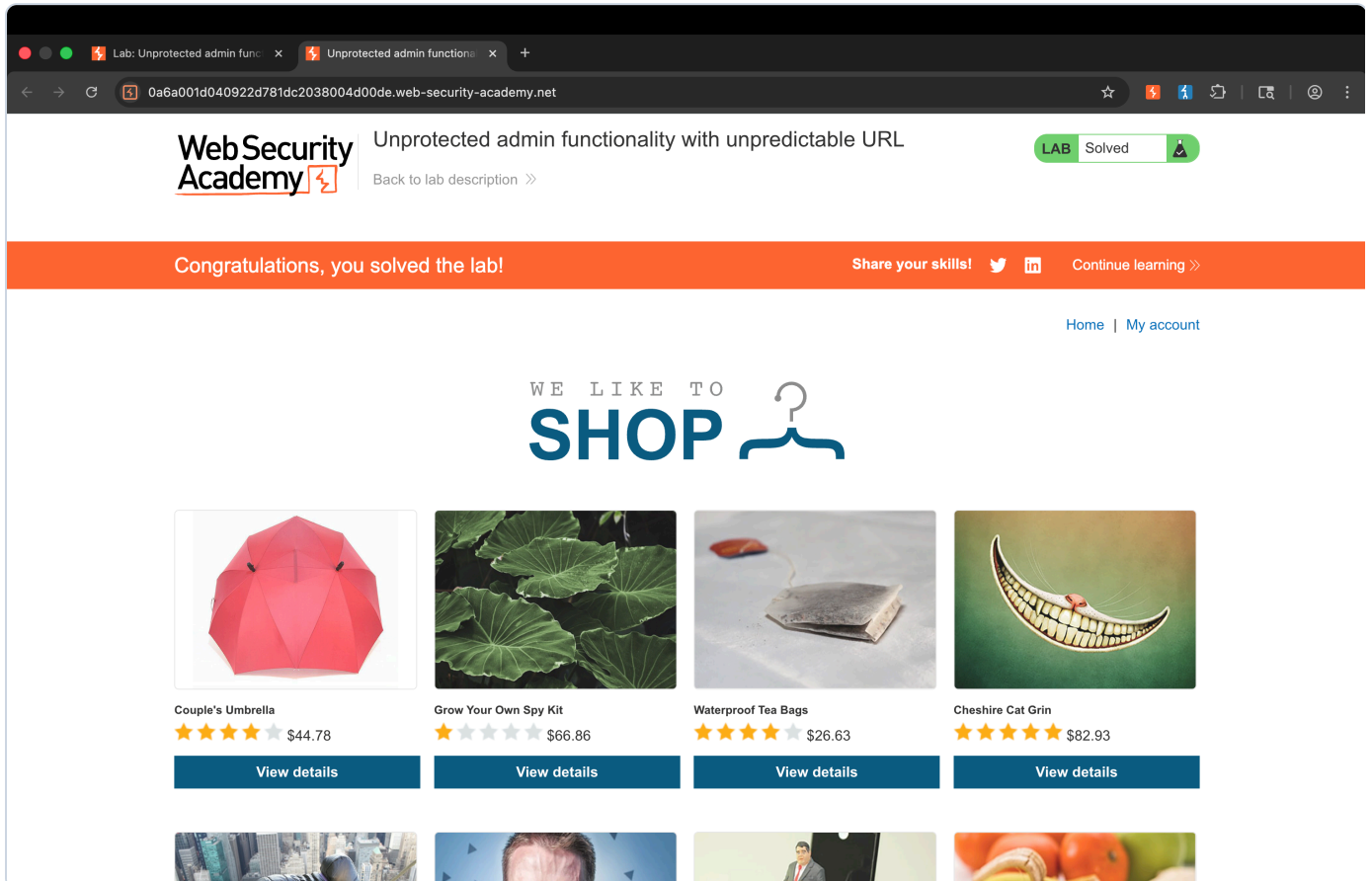
- Attack Vector: Network.
- Attack Complexity: High - requires source code inspection to discover URL.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality / Integrity: High - full admin access after URL discovery.
- Availability: None.

AC Admin URL in JS

Proof of Concept — Exploitation Evidence

Payload / exploit steps are documented in the **Proof of Concept** section of this writeup (above). Screenshot evidence of successful exploitation is shown below.

Lab Solved Confirmation



PortSwigger lab status changed to "Solved" after exploitation.